Fundamentos de Governança de TI

DO DIRECIONAMENTO À CONFORMIDADE

COBIT • ITIL • Riscos • Controles • Conformidade

Seu objetivo
Entender o vocabulário básico, reconhecer situações reais e explicar como os seis assuntos se conectam.

Aprender com uma empresa fictícia

A Loja Aurora vende pela internet. Quando o sistema de pedidos falha, clientes não conseguem comprar. Ao longo do guia, você acompanhará as decisões, os riscos e os controles dessa empresa, do planejamento à recuperação de uma falha.

O que você encontrará

Seis blocos de estudo, três infográficos, exemplos resolvidos, exercícios curtos, um caso integrado, glossário, dez questões comentadas e uma autoavaliação para descrever seu nível de conhecimento.

Nível introdutório
Não exige experiência prévia. Reserve seis sessões de aproximadamente 20 a 30 minutos e uma sessão de revisão. O ritmo é uma sugestão, não uma exigência.

Material independente de estudo. Exemplos, metas e escalas são didáticos. Não é treinamento oficial de certificação nem avaliação de conformidade de uma organização.

Como estudar este guia

Sessão	Leitura	Resultado esperado
1	Páginas 3 a 5	Distinguir governança de gestão.
2	Páginas 6 e 7	Explicar para que serve o COBIT.
3	Páginas 8 a 10	Separar incidente, problema e mudança.
4	Páginas 11 a 13	Descrever e priorizar um risco.
5	Páginas 14 e 15	Ligar controle a evidência.
6	Páginas 16 e 17	Reconhecer obrigações e responsabilidades.
Revisão	Páginas 18 a 24	Aplicar, testar e avaliar seu conhecimento.

Método simples em três passos

Leia: acompanhe o exemplo antes de tentar memorizar siglas.
Explique: feche o material e descreva o conceito em voz alta.
Aplique: responda ao exercício usando um sistema que você conhece.

Critério de aprendizagem
Ao terminar, você deve conseguir explicar um caso com suas próprias palavras e apontar qual evidência sustentaria sua conclusão. Reconhecer uma sigla é só o começo.

Mapa do restante do guia: caso integrado (18), glossário (19), questionário (20 e 21), gabarito (22), autoavaliação (23) e fontes (24).

Um sistema, seis perspectivas

INFOGRÁFICO 1 / Como os assuntos se conectam

GOVERNANÇA
Decide prioridades, responsabilidades e limites.

↓

COBIT
Ajuda a estruturar objetivos de governança e gestão.

↓

ITIL
Orienta a gestão de produtos e serviços para gerar valor.

↓

RISCOS
Examina incertezas que podem afetar objetivos.

↓

CONTROLES
Transforma decisões em medidas verificáveis.

↓

CONFORMIDADE
Verifica aderência às obrigações aplicáveis.

Leitura do mapa: são perspectivas complementares, não etapas obrigatoriamente sequenciais. Riscos e obrigações influenciam decisões desde o início. As evidências ajudam a revisar essas decisões.

Quem decide o quê?

Governança de TI trata de como a organização avalia necessidades, dá direção e acompanha resultados relacionados à informação e à tecnologia. A discussão começa pelo negócio: quais resultados queremos e quais riscos estamos dispostos a assumir?

Gestão transforma essa direção em planos, execução e acompanhamento diário. A distinção está no tipo de decisão e na responsabilidade, não apenas no cargo ou no tamanho da empresa.

Governança	Gestão
Prioriza proteger a operação de vendas.	Planeja melhorias de disponibilidade.
Define quem pode aceitar riscos relevantes.	Analisa riscos e propõe tratamentos.
Acompanha benefícios e exposição ao risco.	Opera, mede e corrige o serviço.

Na Loja Aurora

A direção decide que a próxima campanha só ocorrerá após um teste de recuperação bem-sucedido. A equipe prepara o teste, executa a restauração, registra os resultados e apresenta os limites encontrados. A direção usa essas informações para decidir sobre a campanha.

Pergunta de revisão
“Configurar o backup” é governança ou gestão? É gestão. Decidir a prioridade de continuidade e acompanhar se o risco está aceitável pertence à governança.

Base conceitual: [1] e [2]. Referências e links na página 24.

Valor, responsabilidade e medida

Valor precisa aparecer no resultado

Comprar uma ferramenta é uma entrega. Reduzir a perda de pedidos pode ser um benefício. Antes de investir, a Aurora registra o problema, o resultado esperado, o custo e quem acompanhará o benefício. Assim, uma compra não vira sinônimo automático de sucesso.

Papel no exemplo	Responsabilidade
Direção	Define prioridades e limites de decisão.
Dono do serviço	Responde pelo resultado do serviço de pedidos.
Equipe técnica	Executa e registra as atividades sob sua responsabilidade.
Responsável pelo risco	Acompanha o risco e encaminha decisões à autoridade competente.

Escolha indicadores úteis

Resultado: proporção de pedidos concluídos com sucesso.
Operação: tempo até restaurar o serviço.
Controle: proporção de testes de recuperação concluídos com êxito.

Todo indicador precisa de período, fonte de dados e regra de cálculo. “Temos poucos problemas” não permite comparação. Um número também pode esconder falhas: fechar chamados rapidamente não prova que os clientes voltaram a comprar.

Pratique
Escolha um sistema conhecido. Escreva um benefício que ele deve gerar, quem responde por esse benefício e uma medida que ajude a acompanhá-lo. Exemplo: pedidos concluídos / tentativas válidas de compra no mês.

COBIT: um mapa para organizar

COBIT é um framework da ISACA para governança e gestão da informação e da tecnologia em toda a organização. Um framework oferece uma estrutura de referência que pode ser adaptada ao contexto.

O modelo central do COBIT 2019 contém 40 objetivos de governança e gestão, distribuídos em cinco domínios. Para começar, entenda as famílias de objetivos; não é necessário decorar os 40 nomes.

Domínio	Ideia principal
EDM	Avaliar, direcionar e monitorar: governança.
APO	Alinhar, planejar e organizar: estratégia e organização.
BAI	Construir, adquirir e implementar: soluções e mudanças.
DSS	Entregar, servir e suportar: operação e suporte.
MEA	Monitorar, avaliar e analisar: desempenho e conformidade.

Distinção importante
EDM concentra objetivos de governança; APO, BAI, DSS e MEA concentram objetivos de gestão. Monitorar aparece nos dois contextos, com finalidades e responsabilidades diferentes.

As traduções acima são explicações didáticas. COBIT não é uma ferramenta instalada no servidor nem uma lei. Sua aplicação deve considerar o contexto da organização.

Base conceitual: [1], [2] e [3]. Referências e links na página 24.

Do objetivo à evidência

Uma aplicação didática na Aurora

Necessidade: a campanha não pode provocar uma sequência de pedidos perdidos.
Objetivo do negócio: sustentar vendas confiáveis.
Prioridade de TI: melhorar a capacidade de recuperar o serviço.
Ação: testar a recuperação e corrigir falhas encontradas.
Evidência: relatório com tempo de restauração, dados recuperados e pendências.

Essa sequência é um exercício de raciocínio inspirado no alinhamento entre negócio e tecnologia. Não reproduz a cascata formal de objetivos do COBIT.

Adaptar ao contexto

Uma pequena loja pode começar com poucos registros e responsáveis definidos. Uma organização com operações críticas pode exigir decisões e evidências mais detalhadas. Copiar formulários sem entender a necessidade aumenta o trabalho sem garantir resultado.

Pergunta de diagnóstico	Resposta útil no exemplo
O que queremos proteger?	A capacidade de concluir pedidos.
Quem decide?	A direção, apoiada pelo dono do serviço.
Como saber se melhorou?	Comparar testes e resultados com critérios definidos.

Pratique
Uma empresa compra um sistema caro, mas ninguém sabe qual benefício esperar. Qual é a primeira melhoria? Definir o resultado pretendido, a responsabilidade por acompanhá-lo e como ele será medido.

Base conceitual: [3]. Referências e links na página 24.

ITIL: pensar em serviço e valor

Para um cliente, o valor do sistema da Aurora não está no servidor ligado: está em conseguir comprar e receber o pedido. A gestão de serviços conecta tecnologia, pessoas e rotinas a esse resultado.

ITIL reúne orientações de boas práticas. Na consulta realizada para este guia, a PeopleCert apresenta ITIL (Version 5), com foco na gestão de produtos e serviços digitais. Materiais de ITIL 4 continuam presentes; identifique sempre a versão ao estudar.

Escopo deste capítulo
Vamos trabalhar fundamentos e exemplos operacionais. As fontes das práticas citadas nas próximas páginas são identificadas como ITIL 4. Este guia não apresenta o programa completo nem uma equivalência de certificações entre versões.

Três perguntas para o serviço de pedidos

Quem usa? Clientes e equipe comercial.
Qual resultado precisam alcançar? Registrar e acompanhar compras corretamente.
O que atrapalha esse resultado? Falhas de pagamento, lentidão e informações incorretas.

Melhorar em pequenos ciclos

A Aurora identifica uma dificuldade, escolhe uma mudança limitada, testa, observa os efeitos e ajusta. Uma alteração só é uma melhoria quando o resultado desejado aparece e os efeitos adversos são considerados.

Base conceitual: [4] e [5]. Referências e links na página 24.

Incidente, problema ou mudança?

Conceito	Pergunta central	Exemplo na Aurora
Incidente	Como restaurar o serviço?	O checkout parou de responder.
Problema	Qual causa real ou potencial precisa ser tratada?	Uma falha de software causa travamentos.
Mudança	Como alterar algo com risco avaliado?	Aplicar uma correção no checkout.
Requisição de serviço	Como atender uma solicitação prevista?	Conceder acesso padrão a um novo atendente.

Restaurar o serviço pode ocorrer antes de resolver a causa. Uma solução de contorno permite continuar operando enquanto a investigação avança. Problemas também podem ser identificados antes de causarem novos incidentes.

Uma mudança bem preparada

Antes de atualizar o checkout, a equipe registra o objetivo, avalia o impacto, testa a correção, define a autorização adequada e prepara como voltar ao estado anterior se necessário. Depois, verifica o resultado no serviço.

Pratique
O sistema voltou após uma reinicialização. A causa foi resolvida? Não necessariamente. O incidente pode ter sido recuperado, mas ainda pode existir uma causa que exige investigação.

Uma requisição prevista não deve ser confundida com uma falha. E nem toda mudança precisa da mesma aprovação: o tratamento deve ser proporcional ao risco e às regras estabelecidas.

Base conceitual: [6] e [7]; exemplos de classificação elaborados para este guia. Referências e links na página 24.

Da interrupção ao aprendizado

INFOGRÁFICO 2 / Exemplo didático de recuperação e melhoria

1. DETECTAR E REGISTRAR
Clientes não concluem compras. Registrar horário e alcance.

↓

2. PRIORIZAR E RESTAURAR
Avaliar impacto e urgência. Aplicar recuperação segura.

↓

3. CONFIRMAR COM O NEGÓCIO
Verificar que compras voltaram a funcionar e comunicar.

↓

4. INVESTIGAR A CAUSA
Tratar o problema quando necessário; registrar descobertas.

↓

5. MUDAR E VERIFICAR
Testar a correção, autorizar, implantar e conferir resultados.

As atividades podem se sobrepor. Uma mudança pode ser necessária durante a recuperação. O desenho é um roteiro de entendimento, não um fluxo obrigatório da ITIL.

Exercício: quem deve receber a comunicação além da equipe técnica? Resposta possível: atendimento e dono do serviço, para orientar clientes e acompanhar o impacto.

Descreva o que pode dar errado

Risco envolve incerteza e seus efeitos sobre objetivos. Neste guia, os exemplos priorizam consequências negativas, embora a gestão de riscos possa considerar diferentes efeitos da incerteza.

Escreva um cenário completo

Causa + evento + consequência
Devido à ausência de testes de restauração, um backup defeituoso pode não permitir recuperar os pedidos após uma falha, causando perda de dados e interrupção de vendas.

Ativo: algo de valor, como os dados de pedidos.
Ameaça: circunstância ou agente capaz de causar dano, como uma falha de equipamento.
Vulnerabilidade: fraqueza que pode contribuir para o dano, como a falta de teste de recuperação.
Impacto: consequência para o negócio ou para as pessoas.

Não confunda risco com evento ocorrido

“Podemos perder pedidos” descreve uma possibilidade. “Perdemos pedidos ontem” descreve um evento já ocorrido. O evento deve ser tratado e também pode fornecer evidências para reavaliar riscos futuros.

Pratique
Reescreva “risco de servidor” de forma útil. Uma resposta: “A falha do único servidor pode interromper as vendas porque não existe alternativa de operação”. A nova frase permite discutir ações.

Base conceitual: [8] e [9]. Referências e links na página 24.

Priorizar sem falsa precisão

INFOGRÁFICO 3 / Matriz didática de probabilidade e impacto

Defina critérios antes de classificar. Neste exemplo, considere os próximos 12 meses. A probabilidade deve refletir evidências e contexto; o impacto deve considerar perdas, interrupção, pessoas e obrigações.

Probabilidade / Impacto	Baixo (1)	Médio (2)	Alto (3)
Alta (3)	3 / Moderado	6 / Alto	9 / Alto
Média (2)	2 / Baixo	4 / Moderado	6 / Alto
Baixa (1)	1 / Baixo	2 / Baixo	3 / Moderado

Regra deste exercício: pontuação = probabilidade × impacto. Faixas: 1 a 2, baixo; 3 a 4, moderado; 6 a 9, alto. A cor ou a pontuação não substitui a justificativa. Essa escala não é um padrão obrigatório.

Exemplo resolvido

A Aurora registra falhas recentes e não tem alternativa de operação. Classifica o cenário como probabilidade média (2) e impacto alto (3): 2 × 3 = 6. A prioridade é alta nesta escala. O responsável deve validar as premissas e propor tratamento.

Limite do modelo
Multiplicar categorias não produz uma probabilidade matemática nem uma previsão de prejuízo. Eventos raros e catastróficos podem exigir atenção especial mesmo quando uma matriz simplificada não os destaca.

Pratique: probabilidade alta (3) e impacto médio (2) resultam em 6, prioridade alta. Para comparar dois riscos com 6, examine as consequências e o contexto de cada um.

Tratar, acompanhar e decidir

Resposta	Exemplo didático
Evitar	Desistir de uma integração cujo risco não é aceitável.
Reduzir	Testar recuperação e limitar acessos.
Compartilhar ou transferir	Contratar cobertura ou serviço para parte da exposição; responsabilidades podem permanecer.
Aceitar	Registrar a decisão da autoridade competente, com justificativa e revisão.

Risco inerente: avaliado antes de considerar os controles, conforme a metodologia adotada.
Risco residual: o que permanece após considerar os controles. Ter um controle não significa eliminar o risco.

Um registro mínimo

Descreva o cenário e o objetivo afetado; registre avaliação, controles existentes, ação proposta, responsável, prazo, decisão e data de revisão. Separe controles já operantes de ações apenas planejadas.

Exemplo na Aurora
A loja planeja testar a restauração. Enquanto o teste não acontece, não deve declarar o risco reduzido só porque existe uma tarefa aberta. Após o teste, reavalia o risco com base no resultado e nas limitações observadas.

Apetite a risco expressa o nível ou tipo de risco que a organização se dispõe a assumir. A aceitação de um cenário específico deve respeitar a autoridade e os limites definidos.

Base conceitual: [8], [9] e [10]. Referências e links na página 24.

Controle é uma medida concreta

Um controle é uma medida adotada para modificar riscos ou apoiar o cumprimento de objetivos e requisitos. Pode envolver pessoas, procedimentos e tecnologia. Sua utilidade depende de funcionar no contexto real.

Tipo	Finalidade	Exemplo
Preventivo	Reduzir a chance de ocorrência.	Exigir aprovação antes de conceder acesso privilegiado.
Detectivo	Identificar uma ocorrência ou desvio.	Alertar sobre acessos suspeitos.
Corretivo	Corrigir ou recuperar após uma falha.	Restaurar dados usando uma cópia validada.

Uma medida pode cumprir mais de uma função. O backup apoia a recuperação, mas precisa de execução, proteção e teste. Um arquivo chamado “backup” não prova que o serviço poderá ser restaurado.

Controle manual ou automatizado

Uma revisão humana de permissões é manual. Uma regra que bloqueia contas é automatizada. Ambos precisam de critérios e responsáveis. A automação também pode falhar quando sua configuração ou seus dados estão incorretos.

Pratique
A equipe instala um alerta de falha de backup, mas ninguém recebe as mensagens. O controle está completo? Não. Falta assegurar encaminhamento, acompanhamento e resposta ao alerta.

Base conceitual: [11]; classificação e exemplos didáticos. Referências e links na página 24.

Como demonstrar que funciona

Desenho e execução são perguntas diferentes

Desenho: a medida, se realizada como planejado, atende ao objetivo?
Execução: ela foi realizada corretamente e no período esperado?
Resultado: o teste demonstra o efeito pretendido?

Ficha de controle	Exemplo da Aurora
Objetivo	Recuperar pedidos após falha do sistema.
Atividade	Executar restauração em ambiente de teste.
Responsável e frequência	Equipe designada; periodicidade definida pelo risco.
Critério de êxito	Dados íntegros e tempo dentro da meta aprovada.
Evidência	Registro do teste, horários, resultado e falhas.
Tratamento de exceção	Abrir ação, definir responsável e repetir a verificação.

Uma política assinada mostra que uma regra foi formalizada. Um registro de execução mostra que uma atividade ocorreu. Um teste com resultado verificável ajuda a demonstrar eficácia. As três evidências respondem a perguntas diferentes.

Exercício resolvido
“Fizemos backup todos os dias” prova recuperação? Não. É preciso testar a restauração e verificar os dados. A evidência deve ser adequada ao objetivo e protegida contra acesso ou alteração indevidos.

Base conceitual: [11]. Referências e links na página 24.

Quais obrigações se aplicam?

Conformidade é aderência a requisitos aplicáveis. Quando o requisito vem de lei ou regulamentação, falamos em conformidade legal ou regulatória. Contratos e políticas internas também criam obrigações, com origens diferentes.

Origem	Exemplo e cuidado
Lei ou regulamento	LGPD e regras do setor, quando aplicáveis à atividade.
Contrato	Compromissos de serviço assumidos com clientes.
Política interna	Regra aprovada para conceder acessos.
Norma ou framework	Pode orientar práticas; não se torna lei apenas por ser adotado.

Como transformar requisito em trabalho

Identifique a obrigação e sua origem; determine onde ela se aplica; atribua responsável; estabeleça medidas e evidências; acompanhe mudanças. A análise depende da atividade, dos dados e do setor da organização.

Na Aurora
O contrato promete atendimento em determinado horário. A loja deve organizar o suporte e conservar registros que permitam verificar o compromisso. Cumprir esse contrato, isoladamente, não prova conformidade com todas as leis aplicáveis.

COBIT e ITIL podem apoiar a organização das práticas, mas sua adoção não é prova automática de conformidade. A avaliação concreta dos requisitos deve envolver as áreas responsáveis.

Base conceitual: [12] para o exemplo legal brasileiro. Referências e links na página 24.

LGPD: o básico para reconhecer

A LGPD trata da proteção de dados pessoais. Nome, contato e informações ligadas a uma pessoa identificada ou identificável podem ser dados pessoais. O tratamento inclui atividades como coleta, armazenamento, uso e eliminação.

O **controlador** toma decisões sobre o tratamento; o **operador** trata dados em nome do controlador. Esses papéis dependem da atuação efetiva. O encarregado tem funções próprias de comunicação e orientação, conforme o regime aplicável.

Consentimento não é a única hipótese
É necessário identificar uma hipótese legal adequada ao tratamento. A escolha depende da finalidade e do contexto; coletar um aceite não resolve, por si só, todas as obrigações.

Exercício didático: formulário de compra

A Aurora pede nome, endereço de entrega e data de nascimento para todas as compras. A equipe deve perguntar por que cada campo é necessário. Se não existe finalidade justificável para a data de nascimento, a coleta merece revisão.

Para estudar o caso, faça uma lista: quais dados entram, para que são usados, quem acessa, com quem são compartilhados e por quanto tempo são necessários. Registre as dúvidas para análise dos responsáveis, sem presumir que todo dado deve ser guardado indefinidamente.

E se ocorrer um incidente?

Contenha e investigue, preserve evidências e acione os responsáveis. A necessidade e os critérios de comunicação devem ser avaliados conforme as regras vigentes; nem todo incidente operacional é um incidente com dados pessoais.

Base conceitual: [12], arts. 5º, 6º, 7º, 46 e 48; [13]. Referências e links na página 24.

Caso integrado: campanha Aurora

Na semana anterior à campanha, a loja descobre que o backup nunca foi restaurado em teste. Durante uma simulação, o checkout também falha. A direção precisa decidir se a operação está preparada.

Perspectiva	Ação no caso
Governança	Definir critérios para autorizar a campanha e a autoridade que decide.
COBIT	Organizar objetivos, responsáveis e avaliação do resultado.
ITIL	Restaurar o checkout, investigar a causa e controlar a correção.
Riscos	Avaliar perda de pedidos e indisponibilidade; registrar o tratamento.
Controles	Testar restauração e verificar acesso, integridade e tempo de recuperação.
Conformidade	Identificar obrigações sobre dados e contratos e reunir evidências.

Sua decisão precisa de evidência

Autorizar apenas porque “o servidor está ligado” ignora a recuperação e a compra real. Uma avaliação melhor considera teste de pedido, restauração, pendências, risco residual e decisão registrada pela autoridade competente.

Atividade de 10 minutos
Escreva: 1) um risco; 2) um controle; 3) uma evidência; 4) quem deve decidir. Resposta possível: perda de pedidos; teste de restauração; relatório com dados recuperados; autoridade definida pela direção.

Glossário essencial

Termo	Em linguagem simples
Governança	Direção, decisões e supervisão dos resultados.
Gestão	Planejamento e execução para atingir objetivos.
Framework	Estrutura de referência adaptável ao contexto.
Stakeholder	Pessoa ou grupo que afeta ou é afetado por uma decisão.
Serviço	Meio de apoiar resultados de quem o utiliza.
SLA	Acordo de nível de serviço com compromissos definidos.
Incidente	Interrupção não planejada ou redução da qualidade de um serviço.
Problema	Causa, ou possível causa, de um ou mais incidentes.
Risco residual	Risco que permanece após considerar os controles.
Controle	Medida para tratar riscos ou apoiar requisitos e objetivos.
Evidência	Informação verificável que sustenta uma conclusão.
Compliance	Conformidade com requisitos aplicáveis.
Auditoria	Avaliação sistemática contra critérios, apoiada em evidências.
RTO / RPO	Metas de tempo para recuperação / de perda de dados expressa em tempo.

Exemplo de metas didáticas: RTO de 2 horas e RPO de 1 hora significam pretender recuperar em até 2 horas e limitar a perda a até 1 hora de dados. Precisam ser aprovadas e testadas; não são garantias.

Questionário / parte 1

Marque uma alternativa por questão. Gabarito comentado na página 22.

1. Qual decisão é mais característica de governança?

A) Reiniciar o servidor.
B) Definir a prioridade de continuidade e a autoridade para aceitar riscos.
C) Instalar uma atualização.

2. Para que serve o COBIT?

A) Estruturar a governança e a gestão da informação e tecnologia.
B) Substituir todas as leis aplicáveis.
C) Ser um programa de backup.

3. O checkout caiu e voltou após uma reinicialização. O que podemos afirmar?

A) A causa foi definitivamente eliminada.
B) A conformidade está comprovada.
C) O serviço foi restaurado, mas a causa pode permanecer.

4. Qual cenário representa uma mudança?

A) Um cliente informa indisponibilidade.
B) A equipe implanta uma correção após avaliação e autorização.
C) A direção define a estratégia comercial.

5. Qual frase descreve melhor um risco?

A) Uma falha no servidor único pode interromper as vendas por falta de alternativa.
B) Servidor.
C) TI é importante.

Questionário / parte 2

Marque uma alternativa por questão. Gabarito comentado na página 22.

6. O que é risco residual?

A) Um risco sem responsável.
B) Um risco que não pode ser avaliado.
C) O risco que permanece após considerar os controles.

7. Qual evidência é mais adequada para verificar recuperação de dados?

A) A compra de uma ferramenta.
B) Um teste de restauração com verificação dos dados e resultados.
C) Uma declaração informal de que tudo funciona.

8. Qual é um controle detectivo?

A) Um alerta monitorado de acesso suspeito.
B) A definição de um objetivo de vendas.
C) A decisão de abandonar um projeto.

9. Sobre a LGPD, qual afirmação está correta?

A) Todo tratamento depende obrigatoriamente de consentimento.
B) Usar ITIL garante conformidade legal.
C) É preciso avaliar finalidade, hipótese legal e obrigações aplicáveis.

10. Após estudar este guia, como descrever sua experiência?

A) Afirmar ter liderado uma implantação.
B) Distinguir conhecimento estudado de aplicação profissional comprovável.
C) Declarar uma certificação ainda não obtida.

Gabarito comentado

1 / B - Governança define direção e autoridade. Reiniciar ou atualizar é execução.

2 / A - COBIT orienta governança e gestão. Não substitui obrigações legais nem é software.

3 / C - Restaurar o serviço não comprova eliminação da causa. Pode ser necessário investigar o problema.

4 / B - Implantar uma correção altera o ambiente. Avaliação e autorização ajudam a controlar o risco.

5 / A - A frase relaciona evento possível, condição e consequência para o negócio.

6 / C - Controles podem reduzir a exposição, mas ainda pode restar risco a avaliar e aceitar ou tratar.

7 / B - O teste verifica a capacidade desejada. Comprar uma ferramenta não demonstra eficácia.

8 / A - O alerta ajuda a detectar uma ocorrência; precisa ser acompanhado para apoiar uma resposta.

9 / C - Consentimento é uma das hipóteses legais. A análise deve considerar contexto e obrigações.

10 / B - Estudo, aplicação e certificação são evidências diferentes. Relate apenas o que pode sustentar.

Use o resultado para revisar
8 a 10 acertos: avance para o caso prático. 5 a 7: releia os conceitos das questões erradas. 0 a 4: refaça a trilha com os exemplos. As faixas são didáticas e não certificam competência.

Como falar do seu conhecimento

Para cada tema, registre seu nível e uma evidência. Use a escala abaixo sem transformar a soma em uma credencial. Experiência com algumas práticas não significa implantação completa de um framework.

Nível	O que você consegue demonstrar
0 / Em estudo	Ainda preciso consultar para explicar.
1 / Conhecimento básico	Explico o conceito e reconheço exemplos.
2 / Aplicação em exercício	Resolvo um caso simulado e justifico as escolhas.
3 / Experiência prática	Relato uma aplicação real, meu papel e evidências do resultado.

Preencha: Governança ___ | COBIT ___ | ITIL ___
Riscos ___ | Controles ___ | Conformidade ___

Resposta possível após o estudo

Adapte à sua situação real
“Tenho conhecimentos básicos de Governança de TI, COBIT, ITIL, gestão de riscos, controles e conformidade. Consigo distinguir seus objetivos e aplicar os conceitos em exemplos de estudo. Estou aprofundando a aplicação prática desses temas.”

Se já tiver experiência, acrescente um caso: contexto, sua responsabilidade, ação realizada e resultado verificável. Por exemplo, ter acompanhado revisões de acesso pode demonstrar contato com controles; não prova que você liderou governança corporativa.

Próximo exercício: explique o caso Aurora em dois minutos, sem consultar o guia. Inclua uma decisão, um risco, um controle e uma evidência. Depois verifique onde faltou clareza.

Fontes e notas de versão

Consulta às fontes oficiais: 23/09/2026. Links clicáveis.

[1] ISACA / COBIT

[2] ISACA / Domínios e estratégia de governança

[3] ISACA / Adaptação do COBIT ao contexto

[4] PeopleCert / ITIL e trilhas de qualificação

[5] PeopleCert / ITIL (Version 5) explicada

[6] PeopleCert / ITIL 4: Problem Management

[7] PeopleCert / ITIL 4: Change Enablement

[8] ISO / ISO 31000:2018, gestão de riscos

[9] NIST / Guia de avaliação de riscos, SP 800-30

[10] NIST / Glossário: risco residual

[11] NIST / Avaliação de controles, SP 800-53A Rev. 5

[12] Planalto / Lei Geral de Proteção de Dados

[13] ANPD / Guia sobre agentes de tratamento

Como usar as referências

COBIT 2019 é a referência adotada neste guia. A atualização ITIL (Version 5) foi verificada na PeopleCert; as páginas de práticas ITIL 4 foram identificadas como tal. Consulte o programa oficial da versão desejada antes de estudar para certificação.

Os exemplos da Loja Aurora, a matriz, os exercícios e os infográficos são elaborações didáticas próprias. Não reproduzem diagramas oficiais. As referências NIST oferecem métodos; não são apresentadas aqui como obrigações legais brasileiras.